TEMA 1

# Fundamentos de la gestión y gobierno de la ciberseguridad

Gestión y Administración de la Ciberseguridad

Máster Universitario en Ciberseguridad · Universidad de Salamanca · Curso 2026-2027

**Miguel Puch · mpuchpaino@usal.es**

# Qué vamos a ver hoy

1 **Por qué gobernar, y por qué ahora**
Cuatro incidentes recientes y la presión normativa

2 **Conceptos base**
Activo, amenaza, vulnerabilidad, impacto y riesgo

3 **Gobierno, gestión y operación**
Tres niveles que no conviene confundir

4 **Elementos, roles y terceros**
Quién responde de qué en la organización

5 **SGSI y ciclo de gestión**
Cómo se organiza y se mejora la seguridad

6 **NIST CSF 2.0: la función Govern**
Primera aproximación al marco

7 **Caso práctico en grupos**
Vuestro turno: diagnosticar una empresa

8 **Ideas clave y cierre**
Qué debe quedar claro y qué viene después

# Dónde encaja este tema

**Tema 1**
Fundamentos de gestión y gobierno

**Tema 2**
Gestión de riesgos y protección de la información

**Tema 3**
Marco NIST y estándares internacionales

**Tema 4**
Aspectos legales y regulatorios

**Tema 5**
Ética y privacidad

**Tema 6**
Políticas, procedimientos y controles

**Tema 7**
Auditoría de la ciberseguridad

**Tema 8**
Incidentes y continuidad de negocio

Hoy construimos el **mapa** y el **vocabulario** que se usarán en los siete temas restantes: el resto de la asignatura son piezas de este mismo ciclo.

# Objetivos de la sesión

## Al terminar deberíais poder…

- Distinguir **gobierno, gestión y operación** y decir quién hace qué.
- Explicar por qué la ciberseguridad es una **decisión de dirección**, no solo una compra de tecnología.
- Usar con precisión el vocabulario del riesgo: **activo, amenaza, vulnerabilidad, impacto, riesgo**.
- Describir qué es un **SGSI** y el ciclo de mejora continua.
- Situar la función **GOVERN** del NIST Cybersecurity Framework 2.0.

0 1

# Por qué gobernar, y por qué ahora

- Cuatro incidentes recientes que no se resolvían comprando más tecnología
- Qué exigen hoy NIS2, DORA, el RGPD y el Esquema Nacional de Seguridad
- Por qué la dirección empieza a responder personalmente

# Caso 1 · Change Healthcare (EE. UU., febrero de 2024)

**≈ 190 millones de personas afectadas · ~2.900 M$ de impacto · semanas sin poder facturar recetas en todo EE. UU.**

## Qué ocurrió

- Procesa una parte enorme de la facturación sanitaria de EE. UU.
- Entrada por un **portal de acceso remoto sin doble factor**, con credenciales robadas.
- Días después, **cifrado masivo** y parada de la plataforma.
- Farmacias y hospitales sin cobrar durante semanas.

## Lectura de gobierno

- La tecnología existía: el doble factor estaba comprado, pero **nadie verificaba que estuviera en todos los accesos**.
- Fallo de **inventario de activos**: un servidor heredado quedó fuera del control.
- La dirección acabó compareciendo ante el Congreso: el problema dejó de ser técnico.

Fuentes: comparecencias y comunicaciones públicas de UnitedHealth Group (2024); avisos de CISA. Enfoque de análisis: NIST Cybersecurity Framework 2.0 (funciones GOVERN e IDENTIFY).

# Caso 2 · Marks & Spencer y Co-op (Reino Unido, primavera de 2025)

**Pedidos online parados durante semanas · impacto estimado de cientos de millones de libras · el ataque empezó con una llamada de teléfono**

## Qué ocurrió

- Atacantes especializados en **ingeniería social** (grupo conocido como Scattered Spider).
- Se hicieron pasar por empleados ante el **servicio de asistencia externalizado** y consiguieron restablecer credenciales.
- M&S detuvo su venta online; Co-op sufrió desabastecimiento en tiendas.

## Lectura de gobierno

- El control que falló era un **procedimiento humano de un proveedor**, no un producto.
- Verificar la identidad de quien llama al help desk es **política + formación + contrato**.
- El perímetro de la organización **incluye a sus terceros**: si no los gobiernas, no te gobiernas.

*Fuentes: comunicados de M&S y Co-op y avisos del NCSC británico (2025). Encaja con NIST CSF 2.0: GV.SC (cadena de suministro) y PR.AT (formación).*

# Caso 3 · Jaguar Land Rover (Reino Unido, otoño de 2025)

**Producción detenida durante semanas · miles de proveedores arrastrados · intervención pública para sostener la cadena de suministro**

## Qué ocurrió

- Un ciberataque obligó a **parar las fábricas** y los sistemas de producción y logística.
- La parada se prolongó semanas: no era recuperar datos, era **volver a fabricar**.
- Proveedores pequeños, sin pedidos, al borde del cierre.

## Lectura de gobierno

- La ciberseguridad se convierte en **riesgo de continuidad de negocio**, no en un incidente de TI.
- La pregunta que responde la dirección: **¿cuántos días puede estar parada la empresa?** De ahí salen las inversiones.
- Un incidente en una empresa grande tiene efecto **sistémico** sobre su ecosistema.

Fuentes: comunicados de la compañía e información pública del Gobierno británico (2025). Conecta con el Tema 8: gestión de incidentes y continuidad de negocio (ISO 22301).

# Caso 4 · CrowdStrike, 19 de julio de 2024: no hubo atacante

**Millones de equipos Windows caídos en horas · vuelos, hospitales y bancos parados · ni un solo ciberdelincuente implicado**

## Qué ocurrió

- Una **actualización defectuosa** del propio software de seguridad tumbó los equipos que lo tenían instalado.
- Se distribuyó **a todo el mundo a la vez**, sin despliegue por fases.
- La recuperación exigió tocar los equipos **uno a uno**.

## Lectura de gobierno

- Seguridad no es solo protegerse de atacantes: la **disponibilidad** forma parte de la seguridad.
- **Gestión de cambios** y despliegues escalonados son decisiones de gestión, no caprichos burocráticos.
- Depender de un único proveedor crítico es un **riesgo de concentración** que alguien tiene que haber aceptado por escrito.

Fuentes: informe público de análisis de causa raíz de CrowdStrike (2024) y avisos de agencias nacionales. Marco de lectura: NIST CSF 2.0 (GV.SC, RC.RP) y principios de resiliencia.

# Similitudes entre los casos

1
### Había tecnología
Cortafuegos, antivirus, doble factor, copias... La caja de herramientas estaba comprada.

2
### Falló la organización
Procesos, responsabilidades y verificación: nadie comprobaba que lo comprado funcionara.

3
### El daño fue de negocio
Semanas sin facturar, fábricas paradas, tiendas desabastecidas.

4
### Respondió la dirección
Comparecencias, decisiones de inversión y de continuidad: no era un asunto solo de TI.

Gobernar la ciberseguridad es decidir **quién decide**, con **qué criterios de riesgo**, con **qué recursos** — y comprobar después que se cumple.

Los grandes fallos de seguridad rara vez son fallos de criptografía o de producto: son fallos de incentivos, de responsabilidades mal repartidas y de nadie comprobando nada.

# El gobierno ya no es opcional: la presión normativa

| Norma | A quién aplica | Qué exige en clave de gobierno | Desde cuándo |
|---|---|---|---|
| NIS2 (UE) | Sectores esenciales e importantes | Órganos de dirección responsables y formados; gestión de riesgos; notificación de incidentes | Directiva (UE) 2022/2555, en vigor desde enero de 2023. En España, transposición pendiente (situación a septiembre de 2026)[1] |
| DORA (UE) | Sector financiero y sus proveedores TIC | El órgano de dirección responde del riesgo TIC; control exigente de terceros | Aplicable desde el 17 de enero de 2025 |
| RGPD y LOPDGDD | Quien trate datos personales | Responsabilidad proactiva, medidas según el riesgo; notificar a la autoridad en 72 h las brechas que supongan un riesgo para los derechos de las personas | Desde 2018 |
| ENS (RD 311/2022) | Sector público y sus proveedores | Política de seguridad obligatoria, roles definidos; auditoría (categorías MEDIA y ALTA) o autoevaluación (BÁSICA) | Desde 2022 |
| ISO/IEC 27001:2022 | Voluntaria y certificable | Liderazgo y compromiso de la dirección (cláusula 5) | Referencia internacional |

**Detalle completo en los Temas 3 y 4. Hoy solo interesa la consecuencia: la ley señala a la dirección, no al departamento técnico.**

[1] El plazo de transposición venció el 17/10/2024; el 8/7/2026 la Comisión Europea remitió a España al TJUE por no notificar la transposición completa. Fuente: EUR-Lex.

# Responsabilidades

### SolarWinds (EE. UU., 2023–2025)

La SEC demandó a la empresa **y a su responsable de seguridad** por sus declaraciones públicas sobre seguridad. El tribunal desestimó casi todos los cargos en 2024 y en noviembre de 2025 la SEC retiró el resto. Queda la señal: un CISO puede ser demandado a título personal.

### Uber (EE. UU., 2022)

El antiguo responsable de seguridad fue **condenado penalmente** por ocultar una brecha a los reguladores. Gestionar mal un incidente puede ser delito.

### NIS2 (UE)

Prevé **sanciones económicas relevantes** y responsabilidad de los órganos de dirección, que además deben formarse en gestión de riesgos.

**Debate: ¿quién debería firmar la política de seguridad de una empresa — el responsable de seguridad, el director de TI o el consejero delegado? ¿Y quién responde si no se cumple?**

Pista para el debate: quien firma es quien asume el riesgo. Si la política la firma solo el equipo técnico, la organización está diciendo que la seguridad es un asunto técnico — y ahí empiezan los problemas de gobierno.

02

# Conceptos base

- Activo, amenaza, vulnerabilidad, impacto y riesgo: cinco palabras que hay que distinguir
- Confidencialidad, integridad y disponibilidad, más autenticidad y trazabilidad
- Riesgo inherente, residual y aceptado: quién firma cada cosa

# Conceptos clave

### ACTIVO
Lo que tiene valor para la organización y hay que proteger.

**Caso 1: La plataforma de facturación sanitaria**

### AMENAZA
Quien o qué puede causar daño. No depende de ti.

**Caso 1: Un grupo de ransomware**

### VULNERABILIDAD
La debilidad que la amenaza aprovecha. Sí depende de ti.

**Caso 1: Acceso remoto sin doble factor**

### IMPACTO
La consecuencia para el negocio si llega a ocurrir.

**Caso 1: Semanas sin poder facturar**

### RIESGO
Probabilidad de que ocurra, combinada con el impacto.

**Caso 1: Alto: hay que tratarlo**

**RIESGO = PROBABILIDAD × IMPACTO · lo que se gestiona no son las amenazas, sino el riesgo**

### No puedes eliminar amenazas
Que exista ransomware en el mundo no depende de tu empresa. Lo que sí depende de ti es tener o no un acceso sin doble factor.

### No existe el riesgo cero
Se reduce hasta un nivel que la dirección acepta por escrito. A eso se le llama riesgo residual aceptado.

Stallings (2017); NIST CSF 2.0.

# Qué protegemos: la tríada C · I · D

**C** **CONFIDENCIALIDAD**

Que la información solo la vea quien debe verla.

**Falla cuando se filtran datos de pacientes o de clientes.**

**I** **INTEGRIDAD**

Que la información sea exacta y nadie la altere sin permiso.

**Falla cuando alguien modifica una transferencia o un historial.**

**D** **DISPONIBILIDAD**

Que la información y los servicios estén cuando se necesitan.

**Falla cuando se para la fábrica o caen los equipos (casos 3 y 4).**

**Y dos propiedades que la gestión añade casi siempre:**

### Autenticidad

Que quien dice ser alguien lo sea de verdad. Es exactamente lo que falló en el caso 2: alguien llamó haciéndose pasar por un empleado.

### Trazabilidad

Poder demostrar quién hizo qué y cuándo. Sin registros no hay investigación, ni auditoría, ni prueba ante un regulador.

# Riesgo inherente, controles y riesgo residual

**RIESGO INHERENTE · el que tendrías si no hicieras absolutamente nada**

**Controles: técnicos, organizativos, humanos** → **reducen**

**RIESGO RESIDUAL · lo que queda después**

¿Es aceptable? Lo decide el dueño del riesgo, no el equipo técnico, dentro del **apetito** y la **tolerancia** que fija la dirección.

### EVITAR
No hacer la actividad que genera el riesgo

**Quién: dueño del riesgo o dirección, según el impacto**

### REDUCIR
Implantar controles que bajen el riesgo

**Quién: Propone seguridad, aprueba dirección**

### TRANSFERIR
Seguro o contrato que traslada parte del daño

**Quién: dueño del riesgo, con legal y compras**

### ACEPTAR
Asumirlo por escrito, con fecha y responsable

**Quién: dueño del riesgo según su autoridad; si es material, alta dirección**

**Apetito:** tipo y cantidad de riesgo que la organización está dispuesta a asumir por sus objetivos (alta dirección) → **Tolerancia:** variación aceptable, en niveles o métricas concretas → **Aceptación:** decisión formal sobre un riesgo residual concreto.

# Ejercicio rápido

**Una clínica privada. Para cada elemento, decid en voz alta: ¿activo, amenaza, vulnerabilidad o impacto?**

1. La base de datos de historiales clínicos
2. Un grupo de ransomware especializado en sanidad
3. El servidor de citas sin actualizar desde hace dos años
4. Quince días sin poder atender consultas programadas
5. El personal de admisión, sin formación en phishing
6. La reputación de la clínica en su ciudad

**Pista: si no depende de ti, es una amenaza. Si depende de ti y es una debilidad, es una vulnerabilidad.**

0 3

# Gobierno, gestión y operación

- Qué decide cada nivel, con qué horizonte y con qué productos
- Un mismo caso recorrido de arriba abajo: del acuerdo de dirección al ticket
- Ejercicio en clase: ¿dónde está el fallo en cada situación?

# Análisis comparativo de niveles

| | GOBIERNO | GESTIÓN | OPERACIÓN |
|---|---|---|---|
| **Pregunta que responde** | ¿Qué queremos proteger y cuánto riesgo aceptamos? | ¿Cómo lo conseguimos y con qué recursos? | ¿Cómo se ejecuta hoy, aquí y ahora? |
| **Quién** | Consejo y alta dirección | Responsable de seguridad (CISO) y responsables de área | Equipos técnicos y usuarios |
| **Horizonte** | Años: estrategia | Meses: planes y proyectos | Día a día: turnos y tickets |
| **Productos típicos** | Política, apetito de riesgo, presupuesto, rendición de cuentas | Plan director, procedimientos, proyectos, indicadores | Monitorización, parches, copias, respuesta a incidentes |
| **Si falla…** | Nadie sabe qué es prioritario ni quién responde | Se compran herramientas sueltas sin plan | Hay plan, pero no se ejecuta |

Referencia: ISO/IEC 27014 (gobierno de la seguridad de la información) distingue dirigir y supervisar — gobierno — de planificar y ejecutar — gestión y operación.

# Problema en los niveles

**Punto de partida: la organización no exige doble factor en los accesos remotos — exactamente la debilidad del caso 1.**

| | |
|---|---|
| **GOBIERNO**<br>Consejo y dirección | Deciden: **ningún acceso remoto a sistemas críticos sin doble factor** antes de junio. Aceptan el coste y la incomodidad inicial, asignan presupuesto y nombran un responsable. |
| **GESTIÓN**<br>Responsable de seguridad | Traduce la decisión en un plan: inventario de accesos, elección de solución, despliegue por fases, formación, procedimiento de excepciones y **un indicador**: % de accesos críticos cubiertos. |
| **OPERACIÓN**<br>Equipos técnicos y usuarios | Ejecutan: despliegan, dan soporte, revocan las excepciones caducadas, vigilan las alertas y **reportan el indicador** cada mes. |

**Y el ciclo se cierra: el indicador vuelve a la dirección. Si no se alcanza el objetivo, el gobierno reacciona — más recursos, otro plazo o aceptar el riesgo por escrito.**

ISO/IEC 27014; Anderson (2020).

# Debate

**Debate. Para cada situación, decidid en qué nivel está el fallo principal.**

**A** Se compró una herramienta de detección carísima, pero nadie revisa las alertas que genera.

**B** El responsable de seguridad lleva dos años pidiendo presupuesto y nadie le contesta.

**C** Existe una política de copias de seguridad, pero jamás se ha probado una restauración.

**D** Cada departamento contrata por su cuenta servicios en la nube sin avisar a nadie.

**Casi siempre hay fallo en más de un nivel. La pregunta útil no es "¿quién tiene la culpa?", sino "¿qué decisión falta y quién tiene que tomarla?".**

0 4

# Elementos, roles y terceros

- Las ocho piezas que componen el gobierno de la ciberseguridad
- Quién responde de qué: dirección, TI, CISO, negocio, usuarios y proveedores
- Tres líneas de defensa, independencia del CISO y control de terceros

# Las ocho piezas del gobierno de la ciberseguridad

1
### Contexto
Qué hace la organización, en qué sector, con qué obligaciones legales y qué le puede doler.

2
### Objetivos de negocio
La seguridad existe para que el negocio funcione, no al revés.

3
### Estrategia de seguridad
Adónde queremos llegar en dos o tres años y con qué prioridades.

4
### Roles y responsabilidades
Quién decide, quién ejecuta y quién responde. Por escrito.

5
### Políticas
Las reglas de obligado cumplimiento aprobadas por la dirección.

6
### Recursos
Personas, dinero y tecnología. Sin recursos no hay estrategia, hay deseo.

7
### Supervisión y métricas
Indicadores que llegan a la dirección y provocan decisiones.

8
### Mejora continua
Aprender de incidentes, auditorías y cambios del entorno.

Las ocho piezas aparecen, con otros nombres, en ISO/IEC 27001 (cláusulas 4 a 10) y en la función GOVERN del NIST CSF 2.0.

# Definición de competencias

| Rol | De qué responde | Error típico |
|---|---|---|
| **Alta dirección** | Aprueba la política, fija el riesgo aceptable, asigna recursos y pide cuentas | Delegarlo todo en TI y enterarse el día del incidente |
| **Dirección de TI** | Integra la seguridad en los sistemas y en cada proyecto | Confundir “que funcione” con “que sea seguro” |
| **Responsable de seguridad (CISO)** | Diseña el plan, propone controles, mide y reporta a dirección | Tener el cargo sin autoridad ni presupuesto |
| **Responsables de negocio** | Dicen qué información es crítica y asumen el riesgo de su área | Creer que la seguridad no va con ellos |
| **Administradores y técnicos** | Implantan y operan los controles día a día | Ejecutar sin procedimiento y sin dejar registro |
| **Usuarios** | Cumplen la política; son la primera línea de detección | Pensar que “yo no soy un objetivo” |
| **Proveedores y terceros** | Cumplen los requisitos de seguridad pactados por contrato | Contratar sin cláusulas y sin verificar nada |

**Idea principal: la ciberseguridad no es responsabilidad exclusiva del departamento de TI.**

# Cómo se ordena: el Modelo de las Tres Líneas (IIA)

**Antes llamado «tres líneas de defensa»; el IIA actualizó el modelo en 2020.**

**ÓRGANO DE GOBIERNO · rinde cuentas a los grupos de interés, fija el rumbo y supervisa**

| 1ª LÍNEA<br>Gestión operativa del riesgo | 2ª LÍNEA<br>Supervisión y asesoramiento | 3ª LÍNEA<br>Auditoría interna |
|---|---|---|
| Son los dueños del riesgo: ejecutan la actividad y operan los controles cada día. Incluye negocio, TI y seguridad operativa (SOC, IAM, gestión de vulnerabilidades).<br>**Ejemplo: sistemas aplica los parches.** | Gobierno de seguridad, GRC, riesgos y cumplimiento: definen el marco, asesoran, cuestionan y consolidan la información para la dirección.<br>**Ejemplo: GRC fija la norma de parcheo y mide su cumplimiento.** | Aporta aseguramiento y asesoramiento independientes sobre las dos anteriores. Reporta al órgano de gobierno.<br>**Ejemplo: auditoría revisa si los parches se aplicaron en plazo.** |

**Y por fuera: auditores externos, entidades de certificación y reguladores**

**Se clasifican funciones, no departamentos: una misma área de seguridad puede ejercer funciones de 1ª y 2ª línea.**

Regla de oro: quien opera un control no puede ser quien lo audita.

# Debate: ¿De quién debe depender el responsable de seguridad?

### Opción A · Dentro de TI

+ **A favor**: cercanía técnica, coordinación rápida con sistemas.
– **En contra**: **quien construye se evalúa a sí mismo**; la seguridad compite con los proyectos del propio director de TI y suele perder.

### Opción B · Fuera de TI

+ **A favor**: independencia, acceso directo a dirección, visión de riesgo de toda la organización.
– **En contra**: riesgo de desconexión con la operación si no se cuida la relación con TI.

### Opción C · Comité de seguridad presidido por la dirección

Foro periódico donde se sientan dirección, TI, seguridad, negocio, legal y protección de datos. Aprueba políticas, prioriza inversiones y revisa indicadores. No sustituye al responsable de seguridad: le da respaldo y capacidad de decisión.

### Criterio práctico

No hay una respuesta única, pero sí dos condiciones que deben cumplirse siempre: el responsable de seguridad debe poder **hablar directamente con la dirección** y **nadie debe auditar su propio trabajo**. En organizaciones pequeñas, sin estructura para separar funciones, la solución es apoyarse en auditoría externa.

# Gestión de riesgo de terceros

**En tres de los cuatro casos del inicio, el origen o el amplificador del daño estuvo en un tercero.**

## Quién es un “tercero”

- Proveedores de software y servicios en la nube
- Servicio de asistencia o soporte externalizado
- Mantenimiento, consultoras y personal externo
- Empresas del grupo y filiales adquiridas
- Proveedores de tus proveedores (cuarta parte)

## Qué exige gobernarlos

- Inventario de proveedores **críticos**, no de todos
- Requisitos de seguridad **en el contrato**
- Derecho de auditoría y evidencias periódicas
- Obligación de **notificar incidentes en plazo**
- Plan de salida: qué pasa si el proveedor falla

**Puedes externalizar la tarea, nunca la responsabilidad.**

NIST CSF 2.0 le dedica una categoría completa dentro de GOVERN: GV.SC, gestión del riesgo de la cadena de suministro. NIS2 y DORA lo exigen de forma expresa.

0 5

# El SGSI y el ciclo de gestión

- Qué es y qué no es un Sistema de Gestión de Seguridad de la Información
- Cómo está estructurada la norma ISO/IEC 27001 y qué contiene su Anexo A
- El ciclo planificar–hacer–verificar–actuar como mapa de toda la asignatura

# Qué es y qué no es un SGSI

ISO/IEC 27001:2022; Anderson (2020)

## Qué SÍ es

- Un sistema de gestión: procesos, decisiones y responsabilidades escritas
- Un ciclo que se repite: planificar, hacer, verificar y actuar
- Un enfoque basado en riesgos: se protege lo importante, no todo por igual
- Un conjunto vivo: política, inventario, análisis de riesgos, controles, indicadores y revisiones
- Algo que la dirección aprueba, dota de recursos y revisa

## Qué NO es

- Un programa que se compra e instala
- Una carpeta de documentos para aprobar la auditoría
- Un proyecto con fecha de fin
- Una tarea exclusiva del departamento de TI
- Una garantía de que no habrá incidentes: garantiza un modo ordenado de prevenirlos, detectarlos y aprender

# La norma que lo ordena: ISO/IEC 27001:2022

## Cláusulas 4 a 10 · lo que hay que hacer (es lo que se certifica)

| | |
|---|---|
| 4 | Contexto: Quiénes somos, qué esperan de nosotros y qué alcance tiene el sistema |
| 5 | Liderazgo: La dirección se compromete, aprueba la política y asigna roles |
| 6 | Planificación: Riesgos, oportunidades y objetivos de seguridad medibles |
| 7 | Soporte: Recursos, competencia, concienciación y documentación |
| 8 | Operación: Ejecutar lo planificado y tratar los riesgos |
| 9 | Evaluación: Medir, auditar internamente y revisar por dirección |
| 10 | Mejora: Corregir no conformidades y mejorar de forma continua |

## Anexo A · 93 controles en 4 bloques

**Organizativos · 37 controles**
Políticas, roles, proveedores, continuidad

**Personas · 8 controles**
Selección, formación, teletrabajo, salidas

**Físicos · 14 controles**
Accesos, instalaciones, equipos, soportes

**Tecnológicos · 34 controles**
Identidades, cifrado, copias, registros, red

Los controles se desarrollan en el Tema 6.

# El ciclo de gestión: estructura de la asignatura

**1**
### Objetivos y contexto
¿Qué hay que proteger y por qué?
**Tema 1**

**2**
### Gobierno
La dirección decide, asigna y exige
**Tema 1**

**3**
### Riesgos
¿Qué puede pasar y qué hacemos?
**Tema 2**

**4**
### Marcos y ley
NIST, ISO, RGPD, NIS2, ENS
**Temas 3 y 4**

**5**
### Políticas y controles
Reglas y medidas concretas
**Temas 5 y 6**

**6**
### Operación y supervisión
Ejecutar, medir y auditar
**Temas 6 y 7**

**7**
### Incidentes y mejora
Aprender y volver a empezar
**Tema 8**

**Y vuelta a empezar. El resultado de la mejora cambia los objetivos, y el ciclo se repite: eso es la mejora continua.**

Este esquema es el mismo ciclo planificar–hacer–verificar–actuar (PDCA) que estructura ISO/IEC 27001. Cada parada del recorrido es un tema de la asignatura.

# Estar certificado no es estar seguro

### Lo que sí aporta certificarse

- Disciplina: obliga a documentar, revisar y medir.
- Evidencia ante clientes, socios y reguladores.
- Mirada externa periódica que detecta lo que dentro ya no se ve.
- Requisito comercial: sin ella, muchos contratos ni se presentan.

### Lo que no garantiza

- Que no vayas a sufrir un incidente grave.
- Que los controles se operen bien **todos los días**, y no solo la semana de la auditoría.
- Cobertura completa: la certificación tiene un **alcance definido** y puede dejar fuera media organización.

**La pregunta que debe hacerse la dirección no es "¿estamos certificados?", sino "¿estamos seguros, y cómo lo sabemos?".**

Varias organizaciones con certificaciones y auditorías en regla han sufrido brechas graves en los últimos años. No significa que certificarse no sirva: significa que **cumplir no es lo mismo que estar protegido**, una idea que Anderson subraya en Security Engineering al hablar de incentivos y de seguridad "de cara a la galería".

06

# NIST CSF 2.0 y la función Govern

- Las seis funciones del marco y para qué sirve cada una
- La función GOVERN, añadida en la versión 2.0, y sus seis categorías
- Marco, norma y ley: en qué se diferencian NIST, ISO, el ENS y NIS2

NIST Cybersecurity Framework 2.0 (2024)

# Funciones del NIST CSF 2.0

**GOBERNAR (GOVERN, GV)**

Novedad de la versión 2.0 (2024): envuelve a las otras cinco. Estrategia, expectativas, roles, política, riesgo y supervisión — incluida la cadena de suministro.

### IDENTIFICAR
**ID**

Conocer activos, procesos, riesgos y proveedores. No se puede proteger lo que no se sabe que existe.

### PROTEGER
**PR**

Medidas preventivas: identidades y accesos, formación, cifrado, copias, configuración segura.

### DETECTAR
**DE**

Vigilancia y análisis para descubrir a tiempo lo que está pasando.

### RESPONDER
**RS**

Contener, comunicar, coordinar y gestionar el incidente cuando ocurre.

### RECUPERAR
**RC**

Restaurar los servicios, volver a la normalidad y aprender de lo sucedido.

**Las cinco funciones operativas recorren el ciclo completo: antes del incidente (identificar y proteger), durante (detectar y responder) y después (recuperar).**

Fuente: NIST, Cybersecurity Framework 2.0 (2024). Desarrollo completo en el Tema 3.

# Categorías dentro de GOVERN

GV.OC
### Contexto organizativo
Qué hace la organización, qué esperan de ella sus clientes y la ley, y qué depende de qué.

GV.RM
### Estrategia de riesgo
Qué nivel de riesgo se acepta, con qué criterios se prioriza y cómo se decide invertir.

GV.RR
### Roles y autoridades
Quién decide, quién ejecuta y quién responde. Incluye el compromiso explícito de la dirección.

GV.PO
### Política
La política de seguridad: aprobada, comunicada, revisada y de obligado cumplimiento.

GV.OV
### Supervisión
Comprobar que la estrategia funciona, con indicadores que llegan a la dirección y provocan ajustes.

GV.SC
### Cadena de suministro
Gestionar el riesgo de proveedores y terceros a lo largo de toda la relación contractual.

**Fijaos: son casi exactamente las ocho piezas del gobierno que vimos antes. Marcos distintos, mismo contenido — porque el problema es el mismo en todas partes.**

# Análisis comparativo legal

| | Qué es | ¿Obligatorio? | ¿Se certifica? | Para qué sirve |
|---|---|---|---|---|
| **NIST CSF 2.0** | Marco de referencia, flexible y gratuito | No | No | Organizar y comunicar qué hay que hacer |
| **ISO/IEC 27001:2022** | Norma internacional de sistema de gestión | No, salvo por contrato | Sí | Demostrar que hay un sistema que funciona |
| **ENS (RD 311/2022)** | Norma legal española | Sí, sector público y proveedores | Sí | Garantizar un mínimo común en lo público |
| **NIS2 y DORA** | Legislación europea | Sí, sectores afectados | No como tal | Exigir responsabilidad a la dirección |
| **RGPD y LOPDGDD** | Legislación de protección de datos | Sí | No | Proteger los derechos de las personas |

**Se usan juntos: el marco ordena las ideas, la norma estructura el sistema y la ley marca el mínimo obligatorio. Detalle completo en los Temas 3 y 4.**

0 7

# Caso práctico en grupos

- Una empresa con mucha tecnología y ningún gobierno
- Cinco preguntas para diagnosticarla, en grupos de tres o cuatro personas
- Puesta en común y respuesta comentada

# El supuesto: Clínica Vega, 210 empleados, 4 centros

## Lo que SÍ tienen

- Cortafuegos y antivirus actualizados
- Copias de seguridad diarias
- Doble factor en el correo electrónico
- Un proveedor externo que gestiona los sistemas
- Una certificación ISO 27001 “en trámite”, porque la exige un cliente grande

## Lo que NO tienen

- Ninguna política de seguridad aprobada
- Nadie con la responsabilidad asignada por escrito: “de eso se encarga el informático”
- Inversiones que solo se aprueban después de un susto
- Inventario de proveedores ni cláusulas de seguridad
- Ninguna prueba de restauración de copias, nunca

**Hace tres semanas, una persona de admisión recibió una llamada del “soporte informático” pidiéndole el código de verificación que le acababa de llegar al móvil. Se lo dio.**

**La dirección reacciona pidiendo presupuesto para “una herramienta de inteligencia artificial que detecte ataques”.**

# Ejercicio en grupo

1. ¿Qué problemas de **gobierno** hay? ¿Qué decisiones no se han tomado y quién tenía que tomarlas?
2. ¿Qué problemas de **gestión** hay? ¿Qué falta entre la decisión y la ejecución?
3. ¿Qué debería decidir la **dirección** en su próxima reunión? Tres cosas concretas.
4. ¿Qué debería hacer el **responsable de seguridad** en los próximos tres meses?
5. ¿Qué problemas **no se arreglan** comprando más tecnología?

**ENTREGABLE**

3 decisiones de dirección

3 de gestión

3 de operación

**Una persona por grupo anota; luego compartimos en común dos aportaciones por grupo.**

# Puesta en común

| DIRECCIÓN decide | GESTIÓN organiza | OPERACIÓN ejecuta |
|---|---|---|
| • Aprobar y firmar una política de seguridad<br>• Nombrar un responsable con nombre, tiempo y presupuesto<br>• Fijar qué es inaceptable: por ejemplo, historias clínicas inaccesibles más de 24 horas<br>• Aprobar un presupuesto anual, no reactivo | • Inventario de activos y de proveedores críticos<br>• Análisis de riesgos inicial y plan de tratamiento<br>• Procedimiento de verificación de identidad en el soporte<br>• Formación y simulacros de phishing<br>• Cláusulas de seguridad y derecho de auditoría con el proveedor | • Extender el doble factor más allá del correo<br>• Probar restauraciones cada trimestre<br>• Revisar accesos y excepciones caducadas<br>• Registrar incidentes y reportar indicadores |

Y la respuesta a la pregunta 5: la política, el reparto de responsabilidades, la formación, el control del proveedor y el hábito de probar las copias **no se compran**. Se deciden, se organizan y se sostienen en el tiempo. La herramienta de detección puede ser útil, pero sin lo anterior solo añade alertas que nadie mira.

# Puntos más relevantes de la sesión

1. La ciberseguridad es un problema **organizativo** además de técnico.
2. **Gobierno, gestión y operación** son cosas distintas: decidir, organizar y ejecutar.
3. La **dirección** tiene responsabilidades — y cada vez más, responsabilidad legal.
4. La gestión se basa en **riesgo**: no se protege todo igual y el riesgo cero no existe.
5. Un **SGSI** organiza y mejora la seguridad de forma continua; estar certificado no es estar seguro.

**Ante cualquier organización, la primera pregunta no es qué cortafuegos tiene, sino quién decide — y cómo sabe que se cumple.**

# Próxima sesión

**Tema 2** — **Gestión de riesgos**
Cómo se mide de verdad el riesgo: MAGERIT, ISO 27005, NIST SP 800-30

**Tema 3** — **NIST y estándares**
El marco completo y la familia ISO 27000

**Tema 4** — **Legal y regulatorio**
RGPD, LOPDGDD, ENS, NIS2 y DORA en detalle

**Tema 5** — **Ética y privacidad**
Privacidad desde el diseño y dilemas profesionales

**Tema 6** — **Políticas y controles**
Cómo se escribe y se implanta una política que se cumple

**Tema 7** — **Auditoría**
Cómo se comprueba que todo esto es cierto

**Tema 8** — **Incidentes y continuidad**
Qué hacer cuando falla: ISO 27035 e ISO 22301

**Y en prácticas: taller de defensa de un SGSI y aplicación en una empresa real.**

**La próxima sesión empieza donde termina esta: si la dirección tiene que decidir cuánto riesgo acepta, alguien tiene que saber medirlo. Eso es el Tema 2.**

# Para ampliar: enlaces

**Marcos, normas y recursos adicionales**

- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. https://www.nist.gov/cyberframework
- National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments (NIST Special Publication 800-30 Rev. 1)*. https://csrc.nist.gov/pubs/sp/800/30/r1/final
- SANS Institute. (s. f.). *Information security policy templates*. https://www.sans.org/information-security-policy/
- Center for Internet Security. (s. f.). *CIS Critical Security Controls*. https://www.cisecurity.org/controls
- Instituto Nacional de Ciberseguridad. (s. f.). *INCIBE*. https://www.incibe.es/
- Centro Criptológico Nacional. (s. f.). *CCN-CERT*. https://www.ccn-cert.cni.es/

**Normativa**

- Parlamento Europeo y Consejo de la Unión Europea. (2022). *Directiva (UE) 2022/2555, de 14 de diciembre de 2022, relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión (NIS2)*. https://eur-lex.europa.eu/eli/dir/2022/2555/oj
- Parlamento Europeo y Consejo de la Unión Europea. (2022). *Reglamento (UE) 2022/2554, de 14 de diciembre de 2022, sobre la resiliencia operativa digital del sector financiero (DORA)*. https://eur-lex.europa.eu/eli/reg/2022/2554/oj
- España. (2022). *Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad*.

Miguel Puch · mpuchpaino@usal.es · enlaces y material en Studium

# Bibliografía básica


- Stallings, W. (2017). *Network Security Essentials*. Pearson.
- Anderson, R. (2020). *Security Engineering*. Wiley.
- Jouini, M., & Abeni, A. (2013). *Cyber Security and IT Infrastructure Protection*. Springer.


Miguel Puch · mpuchpaino@usal.es · enlaces y material en Studium